EShop — Main Software Testing Report

Báo cáo kiểm thử và phân tích miền Phạm vi: FR-02 Đăng nhập, FR-08 Checkout, FR-13 Dashboard, FR-15 Quản lý sản phẩm (mobile catalog) **Requirement oracle:** README.md của hệ thống **Thời điểm tổng hợp:** 18-10-2026

> Báo cáo gộp kết quả test run và các phân tích Domain Testing / Boundary Value Analysis (BVA) hiện có.

1. Tóm tắt điều hành

Requirement	Phạm vi	Case	Pass	Fail	Chưa kết luận	Kết luận chính
FR-02	Đăng nhập, khóa, email HTML5, JWT, thông báo	39	27	12	0	Lỗi về bộ đếm/khóa, validate email, token, dữ liệu nhạy cảm và thông báo khóa
FR-08	Checkout, tổng tiền, danh sách hàng, giỏ	9	2	6	1	Tổng do client kiểm soát, UI cho sửa tổng, giỏ không xóa sau thành công
FR-13	Doanh thu và tổng số đơn trên Dashboard	7	5	2	0	Doanh thu đơn delivered bị nhân đôi
FR-15 Mobile	Product CRUD/API và catalog mobile	10	6	4	0	Thiếu validation tên, giá và danh mục
Tổng	**Bốn phạm vi chức năng**	**65**	**40**	**24**	**1**	

2. Mục tiêu, phạm vi và phương pháp

Mục tiêu là đánh giá hành vi trong README.md, nhận diện miền đầu vào, phân hoạch tương đương, áp dụng BVA khi đặc tả có ngưỡng rõ ràng, và tổng hợp test run cho bốn FR. Đặc tả nghiệp vụ là oracle; hành vi hiện tại không thay thế yêu cầu.

Phương pháp gồm đọc yêu cầu, rà soát test case/test run, đối chiếu mã nguồn ở nơi test run nêu rõ, rồi phân loại kết quả theo nguồn bằng chứng. Không chạy lại ứng dụng hoặc khởi tạo backend trong quá trình tổng hợp này. Theo hướng dẫn dự án, backend startup có thể reset/reseed SQLite.

Requirement	Nguồn kết quả	Môi trường / giới hạn
FR-02	tests/test-runs/FR-02/FR02-test-run-001.md, tổng hợp từ báo cáo FR02	Backend API, web login, SQLite;
FR-08	tests/test-runs/FR-08/FR08-checkout-test-run-001.md	Backend API, web login, SQLite;
FR-13	tests/test-runs/FR-13/FR13-dashboard-test-run-001.md	Backend API, web login, SQLite;
FR-15	tests/test-runs/FR-15-mobile/FR15-mobile-test-run-001.md	Backend API, web login, SQLite;

3. Requirement và kết quả

3.1 FR-02 — Đăng nhập và khóa tài khoản

Yêu cầu: mỗi lần sai liên tiếp tăng bộ đếm đúng 1; từ 3 lần sai khóa tạm 30 giây; thông báo không làm lộ chi tiết; login thành công trả JWT, client gửi Bearer token; ô email dùng type=email.

Test run ghi **27 Pass / 12 Fail / 0 chưa chạy** trên 39 case. Các nhóm Fail theo báo cáo:

- Bộ đếm tăng sai và khóa sớm hơn ngưỡng (TC-007, 009, 011–013).
- Tài khoản còn khóa sau thời gian yêu cầu (TC-017; TC-016 được ghi Pass nhưng cách xử lý đúng tại mốc 30 giây cần xác nhận).
- Email input không dùng HTML5 email validation (TC-029, 031).
- Client chấp nhận response thiếu/rỗng JWT và response có plaintext password (TC-034–036).
- UI không thông báo phù hợp khi tài khoản đang bị khóa (TC-038).

Các kết quả này đến từ báo cáo FR-02 đã có; setup theo hướng dẫn README trong đồ án.

3.2 FR-08 — Checkout

Yêu cầu: chỉ người dùng đăng nhập được checkout; tổng tự tính từ giỏ và không sửa trực tiếp; UI hiển thị đủ sản phẩm; backend tự tính; sau thành công xóa giỏ.

Test run ghi **2 Pass / 6 Fail / 1 chưa kết luận** trên 9 case:

- API dùng total_amount do client gửi thay vì tính lại từ giỏ (TC-001, 003, 004, 009), cùng một nhóm nguyên nhân.
- Trường tổng tiền checkout có thể chỉnh sửa (TC-005).
- Luồng thành công không gọi xóa giỏ (TC-001, 007).

TC-002 ghi nhận guest được chuyển tới login và API có middleware xác thực; TC-006 ghi nhận danh sách sản phẩm được hiển thị. TC-008 chưa kết luận vì FR-08 không quy định checkout với giỏ rỗng.

3.3 FR-13 — Dashboard

Yêu cầu: doanh thu chỉ là tổng total_amount của đơn delivered; hiển thị tổng số đơn.

Test run ghi **5 Pass / 2 Fail** trên 7 case. Hai case Fail cùng một lỗi: phép tính totalRevenue nhân đôi total_amount của đơn delivered (TC-001, 006). Các case về đếm đơn, tập delivered rỗng, guest và giao diện chặn role không phải admin được ghi Pass.

TC-004 chỉ kiểm tra UI. Quyền API theo role thuộc FR-12 và chưa được xác nhận đầy đủ; đây là khoảng trống kiểm thử, không kết luận thành bug FR-13.

3.4 FR-15 — Quản lý sản phẩm / Mobile

Yêu cầu: admin tạo/xem/sửa/xóa; tên bắt buộc, tối đa 255 ký tự; giá bắt buộc và dương; danh mục bắt buộc, chọn từ danh sách; cập nhật chỉ ảnh hưởng sản phẩm đích. Mobile xác nhận catalog phản ánh dữ liệu backend, không phải giao diện CRUD admin.

Test run ghi **6 Pass / 4 Fail** trên 10 case. Fail theo rà soát API/schema:

- Không chặn tên vượt 255 ký tự (TC-006).
- Không bắt buộc tên / cho phép tên rỗng (TC-007).
- Không chặn price <= 0 (TC-009).
- Không bắt buộc/liên kết category_id (TC-010).

Các luồng CRUD theo ID và phản ánh dữ liệu trên mobile được ghi Pass. TC-005 ghi nhận tên 254/255 ký tự được lưu; TC-008 ghi nhận giá 1 là dương.

4. Domain Testing — phân tích miền

Các phân hoạch theo đặc tả. Không tạo giới hạn không được quy định; điểm chưa rõ được nêu như ambiguity.

4.1 FR-02

Biến	Miền hợp lệ	Miền không hợp lệ / trạng thái khác	Điều kiện và lưu ý
Email	Format hợp lệ, tài khoản tồn tại	Rỗng, sai format, chưa đăng ký	type=email là yêu cầu UI; không có giới hạn độ dài
Mật khẩu	Khớp tài khoản	Rỗng, không khớp	Không đặt policy độ dài/độ mạnh
Delta bộ đếm	+1 mỗi lần sai	+0, +2 trở lên	Khởi tạo trạng thái trước lần thử
Số lần sai liên tiếp	0–2 chưa khóa; từ 3 khóa	Khóa sai ngưỡng	Ngưỡng 3
Thời gian khóa	Trong 30 giây còn khóa; sau 30 giây được thử lại	Mở sớm / còn khóa quá hạn	Inclusiveness tại đúng 30 giây chưa rõ
Auth/JWT	Credential đúng, không khóa; JWT Bearer hợp lệ	Sai credential, đang khóa, token thiếu/rỗng/sai	Thời hạn JWT không quy định
Output lỗi	Từ chối, thông báo phù hợp, không lộ dữ liệu nhạy cảm	Lộ email, số lần sai, lỗi kỹ thuật/secret hoặc trả thành công giả	Nội dung thông báo khóa cần chốt

4.2 FR-08

Biến	Phân hoạch	Lưu ý
Trạng thái xác thực	Đăng nhập / guest	Guest không được checkout
Giỏ hàng	Có sản phẩm / rỗng	Expected cho giỏ rỗng chưa quy định
Tổng client so với giỏ	Bằng / thấp hơn / cao hơn	Phân hoạch quan hệ; server không tin tổng client
Tổng trên UI	Tự tính/chỉ đọc / chỉnh sửa trực tiếp	Người dùng không được sửa
Đồng bộ cart-total	Giỏ hiện tại khớp / đã đổi sau khi UI hiển thị tổng	Tổng cũ không đại diện cart hiện tại
Kết quả checkout	Thành công / thất bại	Thành công xóa giỏ; preservation khi lỗi cần xác nhận

4.3 FR-13

Biến / trạng thái	Phân hoạch	Lưu ý
Trạng thái đơn	delivered tính doanh thu; pending, confirmed, shipping, canceled không tính	Tổng đơn không loại trạng thái theo FR-13
Tập đơn	Có đơn / rỗng	Test giả định rỗng hiển thị 0; cần review
total_amount	Số hợp lệ / thiếu hoặc sai kiểu	Dữ liệu lỗi chưa có expected
Vai trò	Admin / customer / guest	Quyền truy cập thuộc FR-12; cần API tests riêng

4.4 FR-15

Biến	Miền hợp lệ	Miền không hợp lệ	Điều kiện và lưu ý
Tên sản phẩm	Không rỗng, độ dài <=255	Thiếu/rỗng, dài >255	Whitespace-only chưa rõ

Giá	Số dương >0	Thiếu, 0, âm	Không có max/precision; 1 VND là đại diện dương trong test integer
Danh mục	ID danh mục có sẵn	Thiếu danh mục	ID không tồn tại cần làm rõ
CRUD / đồng bộ	Đúng ID; mobile catalog cập nhật	Bản ghi khác thay đổi hoặc catalog stale	

5. Boundary Value Analysis

BVA chỉ áp dụng cho biến có thứ tự hoặc ngưỡng rõ trong đặc tả. Không tự đặt min/max.

5.1 Biên được đặc tả

FR / biến	Boundary	Giá trị BVA	Phân loại mong đợi	Test case
FR-02: số lần sai	Ngưỡng 3	2 / 3 / 4	Chưa khóa / bắt đầu khóa / vẫn khóa	TC-012 / 013 / 014
FR-02: delta bộ đếm	Chính xác +1	+0 / +1 / +2	Sai / đúng / sai	TC-010 / 009 / 011
FR-02: thời gian khóa	30 giây	29 / 30 / 31 giây	Còn khóa / chưa rõ / được thử lại	TC-015 / 016 / 017
FR-15: độ dài tên	Tối đa 255	254 / 255 / 256 ký tự	Hợp lệ / hợp lệ / sai	TC-005 / 005 / 006
FR-15: giá	Ngưỡng 0, điều kiện >0	-1 / 0 / 1 VND	Sai / sai / đúng	TC-009 / 009 / 008

5.2 Không áp dụng BVA hoặc chưa thể hoàn tất

- **FR-08:** không có min/max cho tổng tiền hay số lượng checkout. Tổng thấp/bằng/cao là EP quan hệ, không phải BVA theo ngưỡng quy định. Giỏ rỗng là trạng thái với expected chưa rõ.
- **FR-13:** không có ngưỡng doanh thu, số đơn hay thời gian; tập đơn rỗng là trạng thái, không phải biên số.
- **FR-02:** email format, role và JWT là lớp phân loại nên dùng EP. Không suy diễn giới hạn email/password, JWT expiry hoặc SLA.
- **FR-15:** category là categorical nên dùng EP; không có mức giá tối đa/precision để phân tích biên trên.

6. Traceability: requirement → domain → test case

Requirement	Miền / biên chính	Test case
FR-02 login/email	Email rỗng, sai format, chưa đăng ký, hợp lệ; password rỗng/sai/đúng	TC-FR-02-LOGIN-001–007, 029–032
FR-02 counter/lock	Delta +1; ngưỡng 3; thời gian 30 giây	TC-FR-02-LOGIN-009–017, 021
FR-02 JWT/error	Token/header partitions; output an toàn	TC-FR-02-LOGIN-022–028, 034–045
FR-08 checkout	Auth, cart, client total, UI total, clear cart	TC-FR-08-CHECKOUT-001–009
FR-13 dashboard	Order status, empty set, count, access UI	TC-FR-13-DASHBOARD-001–007
FR-15 product	CRUD, tên, giá, category, mobile propagation	TC-FR-15-PRODUCT-MOBILE-001–010

7. Tổng hợp defect candidates

Các bug report chi tiết đã có; các case cùng nguyên nhân được gom để tránh issue trùng.

FR	Defect candidate	Case liên quan	Bằng chứng

FR-02	Bộ đếm tăng 2 và khóa sớm	007, 009, 011–013	Báo cáo kiểm thử hiện có
FR-02	Khóa lâu hơn 30 giây	016–017	Báo cáo kiểm thử; mốc 30 cần làm rõ
FR-02	Email input không dùng type=email	029, 031	Báo cáo kiểm thử
FR-02	Client nhận response thiếu/rỗng token	034–035	Báo cáo kiểm thử
FR-02	Login response có plaintext password	036	Báo cáo kiểm thử
FR-02	UI không báo tài khoản bị khóa	038	Báo cáo kiểm thử
FR-08	Backend tin total_amount từ client	001, 003, 004, 009	Source review; Báo cáo kiểm thử
FR-08	Tổng UI sửa được	005	Source review; Báo cáo kiểm thử
FR-08	Giỏ không xóa sau checkout thành công	001, 007	Source review; Báo cáo kiểm thử
FR-13	Doanh thu delivered bị nhân đôi	001, 006	Source review; Báo cáo kiểm thử
FR-15	Không chặn tên >255	006	API/schema review; Báo cáo kiểm thử
FR-15	Cho phép tên thiếu/rỗng	007	API/schema review; Báo cáo kiểm thử
FR-15	Cho phép giá <=0	009	API/schema review; Báo cáo kiểm thử
FR-15	Cho phép thiếu category	010	API/schema review; Báo cáo kiểm thử

Tài liệu issue: FR-02/08/13/15 tổng hợp, FR-13/15 riêng, FR-02 bug report.

8. Giới hạn, giả định và human review

Ambiguities

- FR-02: chưa rõ lúc reset bộ đếm; mở khóa đúng tại 30.000 ms hay không; thời hạn JWT và status/body cũng chưa định nghĩa đầy đủ.
- FR-08: checkout giỏ rỗng, giữ giỏ khi lỗi, API có nhận request thiếu total_amount hay không. Cần đối chiếu API example với yêu cầu server tự tính.
- FR-13: hiển thị tập đơn rỗng, dữ liệu total_amount lỗi, thời điểm refresh. Phân quyền API thuộc FR-12.
- FR-15: tên chỉ có khoảng trắng, precision/giá tối đa, expected cho category ID không tồn tại.

Human review required

1. Xác nhận diễn giải FR và expected của các miền, nhất là điểm còn mơ hồ.
2. Kiểm tra trạng thái reset/reseed an toàn trước khi chạy lại case thay đổi dữ liệu.
3. Tái hiện finding FR-08/13/15 trong môi trường test cô lập, lưu request/response, số liệu hoặc screenshot.
4. Kiểm tra API role riêng cho FR-12; không suy kết luận bảo vệ backend từ UI.

AI gap candidates

- **FR-02 counter reset:** đặc tả chưa nói rõ reset sau login thành công/hết khóa; cần xác nhận rồi bổ sung case.
- **FR-02 đúng 30 giây:** oracle chưa chốt inclusiveness.
- **FR-08 stale cart:** TC-009 nhắm tương tác cart thay đổi sau khi tổng hiển thị; cần quan sát cart server-side và order.
- **FR-13 dữ liệu lỗi:** thiếu/sai kiểu total_amount chưa có expected behavior.
- **FR-15 category ID không tồn tại / tên chỉ có khoảng trắng:** chưa được run xác nhận; cần chốt expected.